

Zadanie ćwiczeniowe — Bezpieczny system logowania w PHP

Cel zadania

Twoim zadaniem jest stworzenie bezpiecznego formularza logowania w PHP z wykorzystaniem bazy danych MySQL.

Aplikacja ma być odporna na podstawowe ataki webowe oraz zawierać mechanizmy zabezpieczające stosowane w prawdziwych aplikacjach.

Wymagania funkcjonalne

Użytkownik powinien móc:

- wpisać login i hasło,
- wysłać formularz logowania,
- zostać poprawnie zalogowany po podaniu poprawnych danych,
- otrzymać komunikat o błędzie przy błędnych danych.

Wymagane zabezpieczenia

1. Prepared Statements (ochrona przed SQL Injection)

Zapytania SQL muszą być wykonywane przy użyciu:

- `prepare()`
- `bind_param()`

NIE wolno łączyć danych użytkownika bezpośrednio w zapytaniu SQL.

Przykład NIEPOPRAWNY:

```
$sql = "SELECT * FROM users WHERE username = '$login'";
```

2. Bezpieczne hasła

Hasła w bazie danych muszą być zapisane jako hash przy użyciu:

`password_hash()`

Podczas logowania należy użyć:

`password_verify()`

Nie wolno przechowywać haseł jako zwykły tekst.

3. Walidacja loginu (regex)

Login użytkownika:

- może zawierać:
 - małe litery,
 - duże litery,
 - cyfry,
 - znak _
- długość:
 - minimum 3 znaki,
 - maksimum 20 znaków.

Należy użyć:

`preg_match()`

4. CSRF Token

Formularz musi być zabezpieczony przed atakiem CSRF.

Wymagania:

- token zapisany w `$_SESSION`
- token dodany do formularza jako `hidden input`
- sprawdzanie tokenu po wysłaniu formularza.

5. Ochrona przed brute force

Po kilku nieudanych próbach logowania użytkownik powinien zostać czasowo zablokowany.

Przykład:

- 5 błędnych prób,
- blokada na 5 minut.

Mechanizm można zaimplementować przy użyciu:

`$_SESSION`
`time()`

6. Bezpieczne komunikaty błędów

Nie wolno ujawniać szczegółów technicznych takich jak:

- nazwa bazy,
- struktura SQL,
- stack trace,
- błędy systemowe,
- nazwa użytkownika bazy danych.

Poprawny komunikat:

Wystąpił błąd systemu.

Niepoprawny komunikat:

SQL syntax error near...

Wymagania techniczne

Baza danych

Utwórz tabelę:

```
CREATE TABLE users (  
    id INT AUTO_INCREMENT PRIMARY KEY,  
    username VARCHAR(50) UNIQUE,  
    password VARCHAR(255)  
);
```

Dodatkowe wymagania

Kod powinien zawierać komentarze wyjaśniające:

- czym jest SQL Injection,
- czym jest CSRF,
- dlaczego hasła są hashowane,
- czym jest brute force.

Zadanie dodatkowe

Dodaj:

- wylogowanie użytkownika,
- regenerację session ID po zalogowaniu,
- timeout sesji po 10 minutach.